

CanlıFal — Güvenlik Dokümantasyonu

§73, §49-50, §59, §78 — Spec Referansları

Son güncelleme: 2026-08-27

1. Authentication (Kimlik Doğrulama)

1.1 Dual Auth Mimarisi

Yöntem	Token	Geçerlilik	Kullanım
Mobile JWT	Authorization: Bearer <token>	Access 7 gün, Refresh 30 gün	Flutter
Web Session	next-auth cookie	Oturum bazlı	Web tarayıcı

- Merkezi doğrulama: `authenticateRequest(req)` → JWT önce, web session fallback
- Token yenileme: `POST /api/mobile/refresh-token`
- 60 saniyelik auth önbelleği (`lib/perf.ts`)

1.2 Hassas Bilgi Koruması

- API key/secret Flutter içine konulmaz
- JWT secret sadece sunucu tarafında (`.env`)
- Şifreler bcrypt ile hash'lenir
- Token'lar HttpOnly cookie'lerde saklanır (web)

2. Rate Limiting

2.1 Katmanlar

Katman	Kapsam	Pencere	Limit
authLimiter	Auth uçları (login, signup, forgot-password)	15 dk	10 istek
heavyLimiter	Ağır işlemler (gifts/send legacy)	1 dk	10 istek
guardRateLimit	30 korumalı uç (finansal, mesaj, yorum, içerik, şikayet, upload)	1 dk	Scope'a göre değişir

2.2 Guard Rate Limit Scope'ları

Scope	Limit/dk	Korunan Uç Sayısı
api_default	60	Genel
gift_send	10	4
lucky_gift	10	1
chat_message	30	3
comment	20	5
content_create	10	2
tip	10	1
membership	5	1
withdrawal	5	2
payment	10	1
stream_create	5	1
room_create	5	1
pk_create	10	3
agency_action	5	2
report	5	3
upload	5	1

Limitler `rate_limits` RemoteConfig kaydından ezilebilir (60sn cache).

3. Idempotency (Tekrar Koruması)

4 finansal uç noktada `Idempotency-Key` header desteği:

Uç Nokta	Scope
POST /api/withdrawals	withdrawal
POST /api/payments/requests	payment_request
POST /api/room/[sessionId]/tip	tip
POST /api/memberships/purchase	membership_purchase

- 24 saat TTL, 60 saniyelik in-flight bayatlama
- Header yoksa idempotency atlanır (geriye uyumlu)
- Model: IdempotencyRecord (key @unique, scope, status, responseBody)

4. Anti-Fraud (Dolandırıcılık Tespiti)

4.1 Risk Skorlama Sistemi

lib/risk-score.ts — fire-and-forget, ana akışı kesmez.

Sinyal	Ağırlık	Tetikleyici
new_account	25	Hesap < 24 saat
young_account	12	Hesap < 7 gün
velocity	20	Son 60dk $\geq$ 3 risk olayı
amount_spike	20	30g kategori ortalamasının 5x'i
first_large_withdrawal	15	İlk çekim $\geq$ 1000
rapid_topup_withdraw	20	Son 60dk yükleme talebi varken çekim
large_amount	15	$\geq$ 5000

4.2 Risk Seviyeleri

Seviye	Skor Aralığı
low	0-29
medium	30-54
high	55-79
critical	80+

4.3 İzlenen Uçlar

Uç Nokta	Kategori
POST /api/withdrawals	withdrawal
POST /api/payments/requests	payment_request

4.4 Admin İnceleme

- GET /api/admin/risk-events — Filtreleme: level, category, userId, reviewed
- PATCH /api/admin/risk-events/[eventId] — İnceleme notu + reviewed işareti
- Admin paneli: /admin/risk

5. Immutable Ledger (Değiştirilemez Defter)

LedgerEntry modeli — çift-kayıt muhasebe. UPDATE/DELETE yok.

Alan	Açıklama
transactionId	UUID, aynı işlemin tüm bacakları aynı
accountType	user, platform, agency
direction	credit / debit
balanceBefore/After	İşlem öncesi/sonrası bakiye
category	gift_send, withdrawal, tip, fortune_session, membership, daily_bonus, admin_adjust

10 uç noktada fire-and-forget entegre.

6. Audit Log (Denetim Kaydı)

`AuditLog` modeli — sadece ekleme.

Kaydedilen aksiyonlar:

- `balance_adjust`, `withdrawal_approve`, `withdrawal_reject`, `withdrawal_complete`
- `feature_toggle`, `feature_delete`
- `role_create`, `role_update`, `role_delete`
- `verification_approve`, `verification_reject`
- `effect_rule_create`, `effect_rule_update`, `effect_rule_delete`
- `risk_event_review`

Admin paneli: `/admin/audit` (iki sekme: Denetim Kaydı + Finansal Defter)

7. Transaction Safety

`prisma.$transaction` kullanılan 33+ dosya:

- Koltuk ataması (seat assignment)
- Hediye gönderimi (coin düşürme + alıcı artırma + skor güncelleme)
- Para çekme (bakiye güncelleme + talep oluşturma)
- Üyelik satın alma (ödeme + bonus jeton)
- Ajans komisyonu
- Takım puanı

8. Cihaz Yönetimi

- `POST /api/devices/fcm` — FCM token kaydetme (OneSignal'a ek)
- Cihaz bilgileri login sırasında yakalanır
- Push bildirim: OneSignal kanonik (`lib/push.ts`)

9. CORS ve Güvenlik Header'ları

- `x-request-id` her yanıtı eklenir (`middleware.ts`)
- `x-api-version: v1` yanıt header'ı
- Rate limit header'ları: `Retry-After`, `X-RateLimit-Limit`, `X-RateLimit-Remaining`, `X-RateLimit-Reset`

10. Personel Finansal Muafiyeti

`isStaffSpender(role)` → admin/yonetici rollerinde:

- Jeton düşülmez (sınırsız bakiye)
- Alıcıya kazanç yazılmaz
- Ajans komisyonu hesaplanmaz
- Hediye animasyonları ve bildirimler normal çalışır